

CCS6224

Network Security

Lecture 10
Transport-Level Security

Outline

- › Web Security
- › Secure Socket Layer
- › HTTPS
- › Transport-Level Security
- › Secure Shell

Web Security Considerations

- › The World Wide Web is fundamentally a client/server application running over the Internet and TCP/IP intranets
- › The following characteristics of Web usage suggest the need for tailored security tools:
 - Web servers are relatively easy to configure and manage
 - Web content is increasingly easy to develop
 - The underlying software is extraordinarily complex
 - › May hide many potential security flaws
 - A Web server can be exploited as a launching pad into the corporation's or agency's entire computer complex
 - Casual and untrained (in security matters) users are common clients for Web-based services
 - › Such users are not necessarily aware of the security risks that exist and do not have the tools or knowledge to take effective countermeasures

	Threats	Consequences	Countermeasures
Integrity	•Modification of user data •Trojan horse browser •Modification of memory •Modification of message traffic in transit	•Loss of information •Compromise of machine •Vulnerability to all other threats	Cryptographic checksums
Confidentiality	•Eavesdropping on the net •Theft of info from server •Theft of data from client •Info about network configuration •Info about which client talks to server	•Loss of information •Loss of privacy	Encryption, Web proxies
Denial of Service	•Killing of user threads •Flooding machine with bogus requests •Filling up disk or memory •Isolating machine by DNS attacks	•Disruptive •Annoying •Prevent user from getting work done	Difficult to prevent
Authentication	•Impersonation of legitimate users •Data forgery	•Misrepresentation of user •Belief that false information is valid	Cryptographic techniques

Table 17.1 A Comparison of Threats on the Web

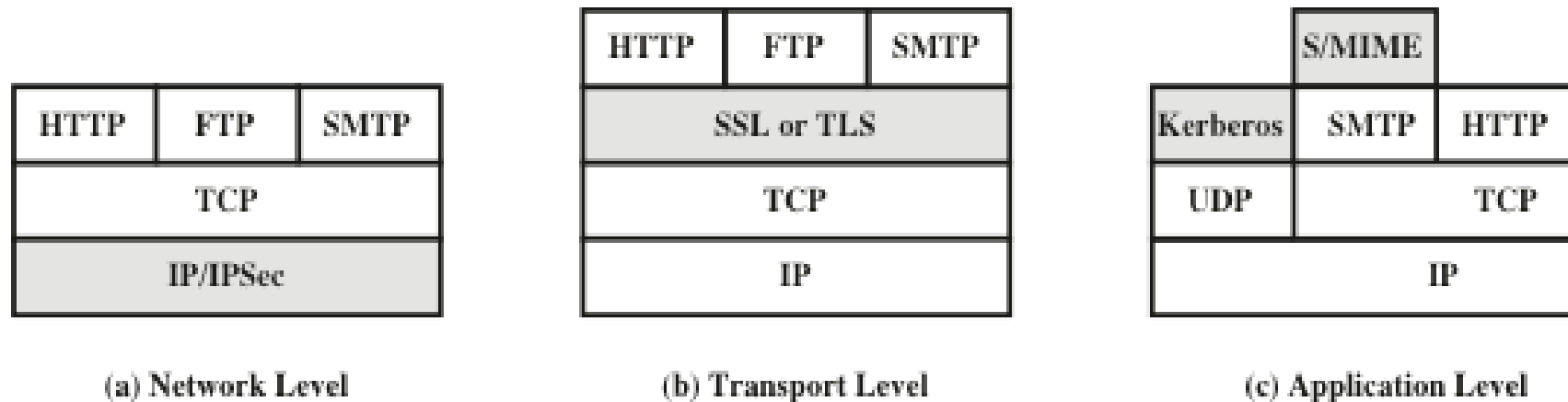


Figure 17.1 Relative Location of Security Facilities in the TCP/IP Protocol Stack



Secure Sockets Layer (SSL)

- › One of the most widely used security services
- › A general purpose service implemented as a set of protocols that rely on TCP
 - Could be provided as part of the underlying protocol suite and therefore be transparent to applications
 - Can be embedded in specific packages
- › Subsequently become Internet standard known as TLS (Transport Layer Security)
- › Use TCP to provide a reliable end-to-end service
- › SSL has two layers of protocols

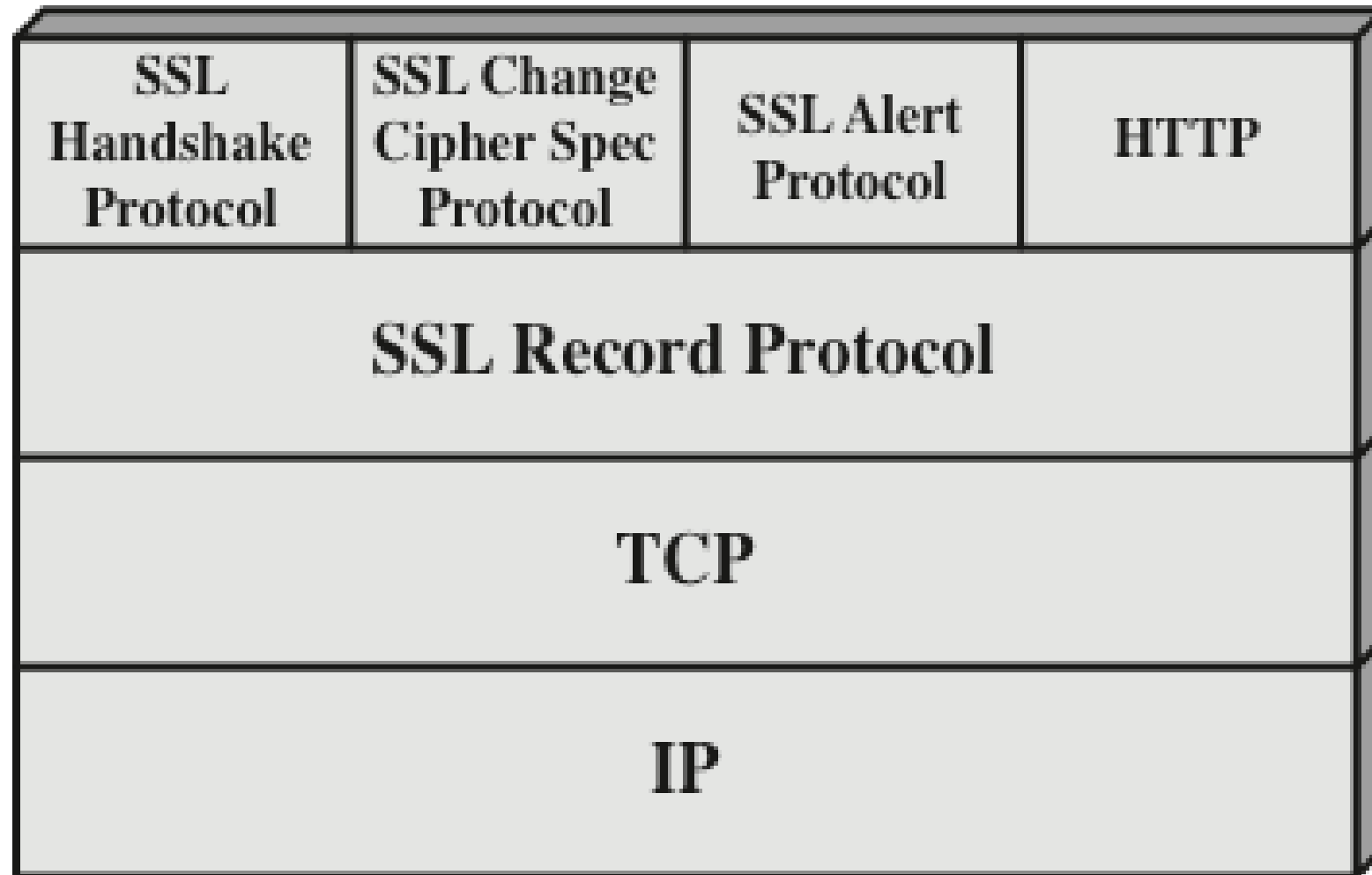


Figure 17.2 SSL Protocol Stack



SSL Architecture

› Two important SSL concepts are:

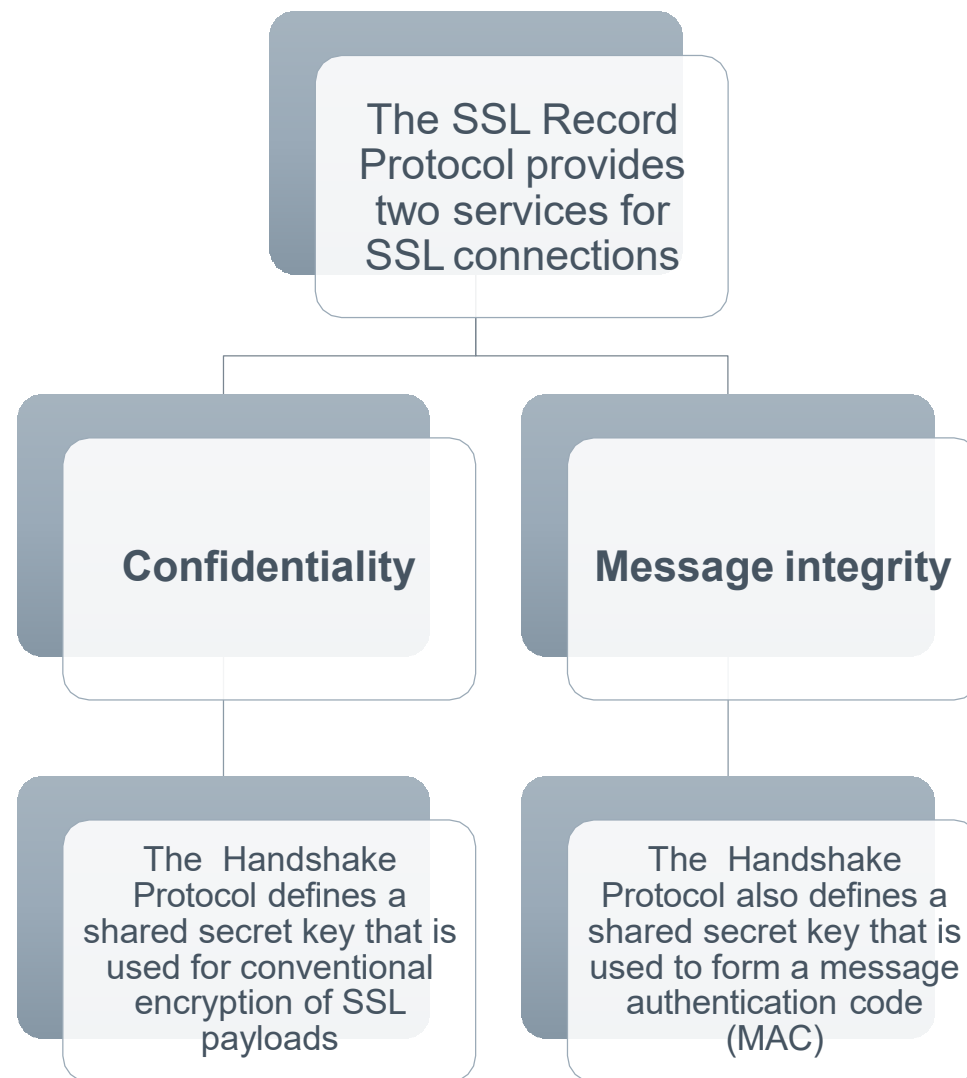
SSL connection

- A transport that provides a suitable type of service
- For SSL such connections are peer-to-peer relationships
- Connections are transient
- Every connection is associated with one session

SSL session

- An association between a client and a server
- Created by the Handshake Protocol
- Define a set of cryptographic security parameters which can be shared among multiple connections
- Are used to avoid the expensive negotiation of new security parameters for each connection

SSL Record Protocol



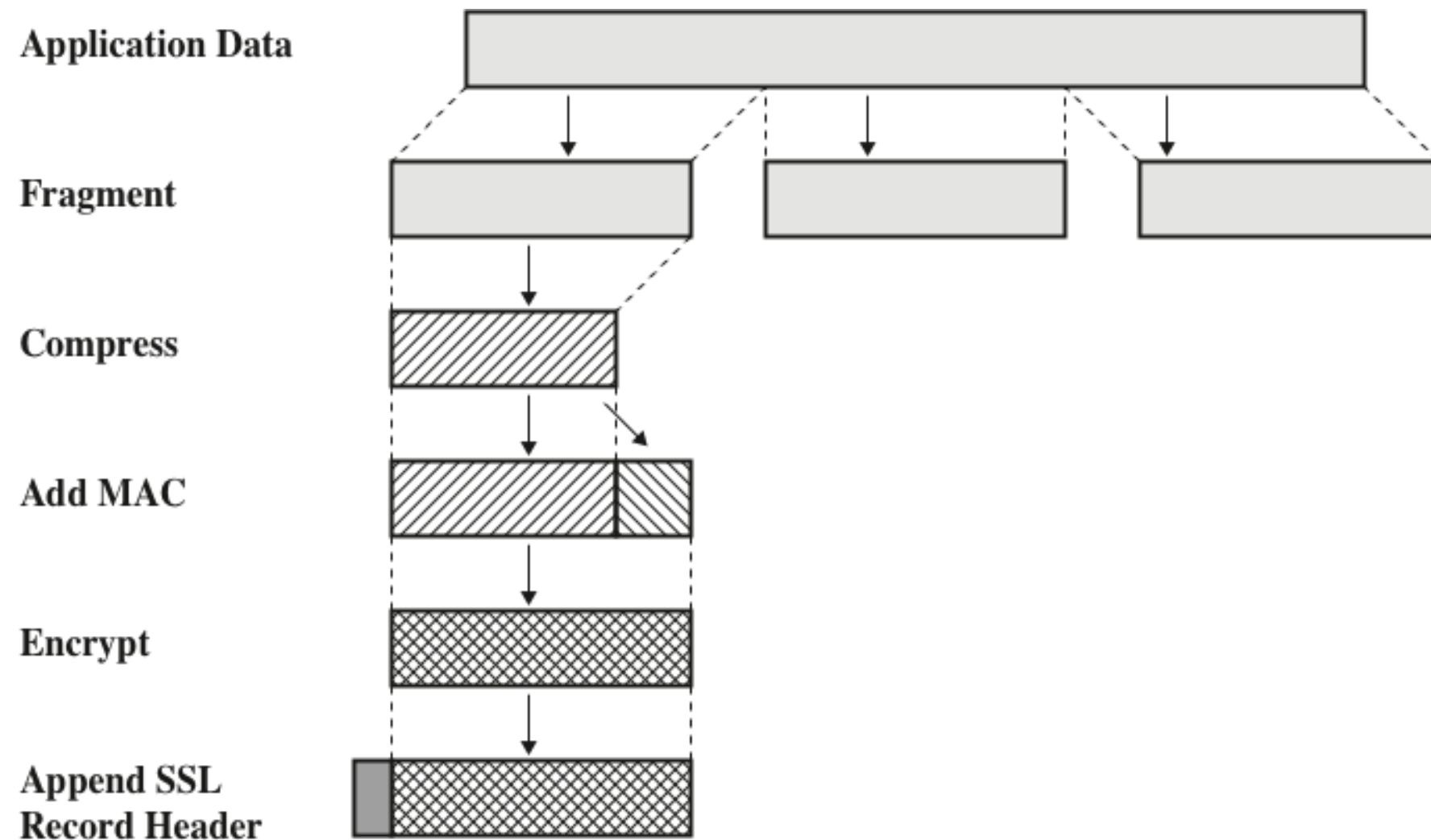


Figure 17.3 SSL Record Protocol Operation

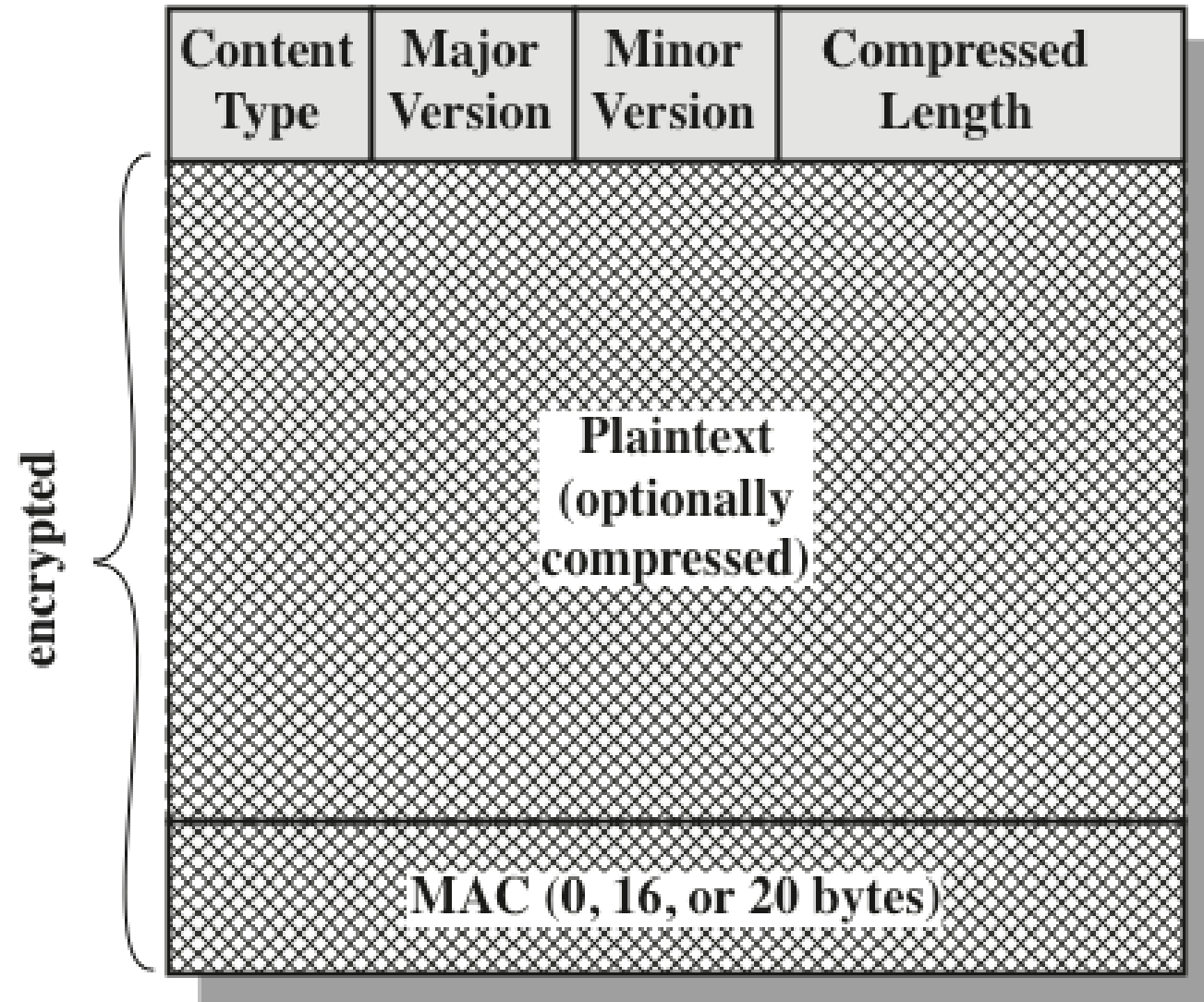


Figure 17.4 SSL Record Format

SSL Change Cipher Spec Protocol

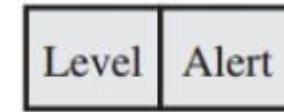
- › One of 3 SSL specific protocols which use the SSL Record protocol
- › A single message (single byte)
- › Cause pending state to become current
- › Hence updating the cipher suite in use

```
Secure Sockets Layer
  TLSv1.2 Record Layer: Handshake Protocol: Client Key Exchange
    Content Type: Handshake (22)
    Version: TLS 1.2 (0x0303)
    Length: 70
    Handshake Protocol: Client Key Exchange
      Handshake Type: Client Key Exchange (16)
      Length: 66
      EC Diffie-Hellman Client Params
        Pubkey Length: 65
        Pubkey: 04954cb574c8908d619e22d5ea86afd14f1e321de25359f6...
  TLSv1.2 Record Layer: Change Cipher Spec Protocol: Change Cipher Spec
    Content Type: Change Cipher Spec (20)
    Version: TLS 1.2 (0x0303)
    Length: 1
    Change Cipher Spec Message
  TLSv1.2 Record Layer: Handshake Protocol: Encrypted Handshake Message
    Content Type: Handshake (22)
    Version: TLS 1.2 (0x0303)
    Length: 40
    Handshake Protocol: Encrypted Handshake Message
```

SSL Alert Protocol

- › Conveys SSL-related alerts to peer entity
- › Severity: **warning** or **fatal**
- › Fatal: unexpected message, bad record mac, decompression failure, handshake failure, illegal parameter
- › Warning: close notify, no certificate, bad certificate, unsupported certificate, certificate revoked, certificate expired, certificate unknown

1 byte 1 byte



(b) Alert Protocol

```
▼ Secure Sockets Layer
  ▼ TLSv1 Record Layer: Alert (Level: Fatal, Description: Close Notify)
    Content Type: Alert (21)
    Version: TLS 1.0 (0x0301)
    Length: 2
    ▼ Alert Message
      Level: Fatal (2)
      Description: Close Notify (0)
```

SSL Handshake Protocol

- › Allows client and server to:
 - Authenticate each other
 - To negotiate encryption and MAC algorithms
 - To negotiate cryptographic keys
- › Comprises a series of messages in phases
 - Establish Security Capabilities
 - Server Authentication and Key Exchange
 - Client Authentication and Key Exchange
 - Finish

Message Type	Parameters
hello_request	null
client_hello	version, random, session id, cipher suite, compression method
server_hello	version, random, session id, cipher suite, compression method
certificate	chain of X.509v3 certificates
server_key_exchange	parameters, signature
certificate_request	type, authorities
server_done	null
certificate_verify	signature
client_key_exchange	parameters, signature
finished	hash value

Table 17.2 SSL Handshake Protocol Message Types

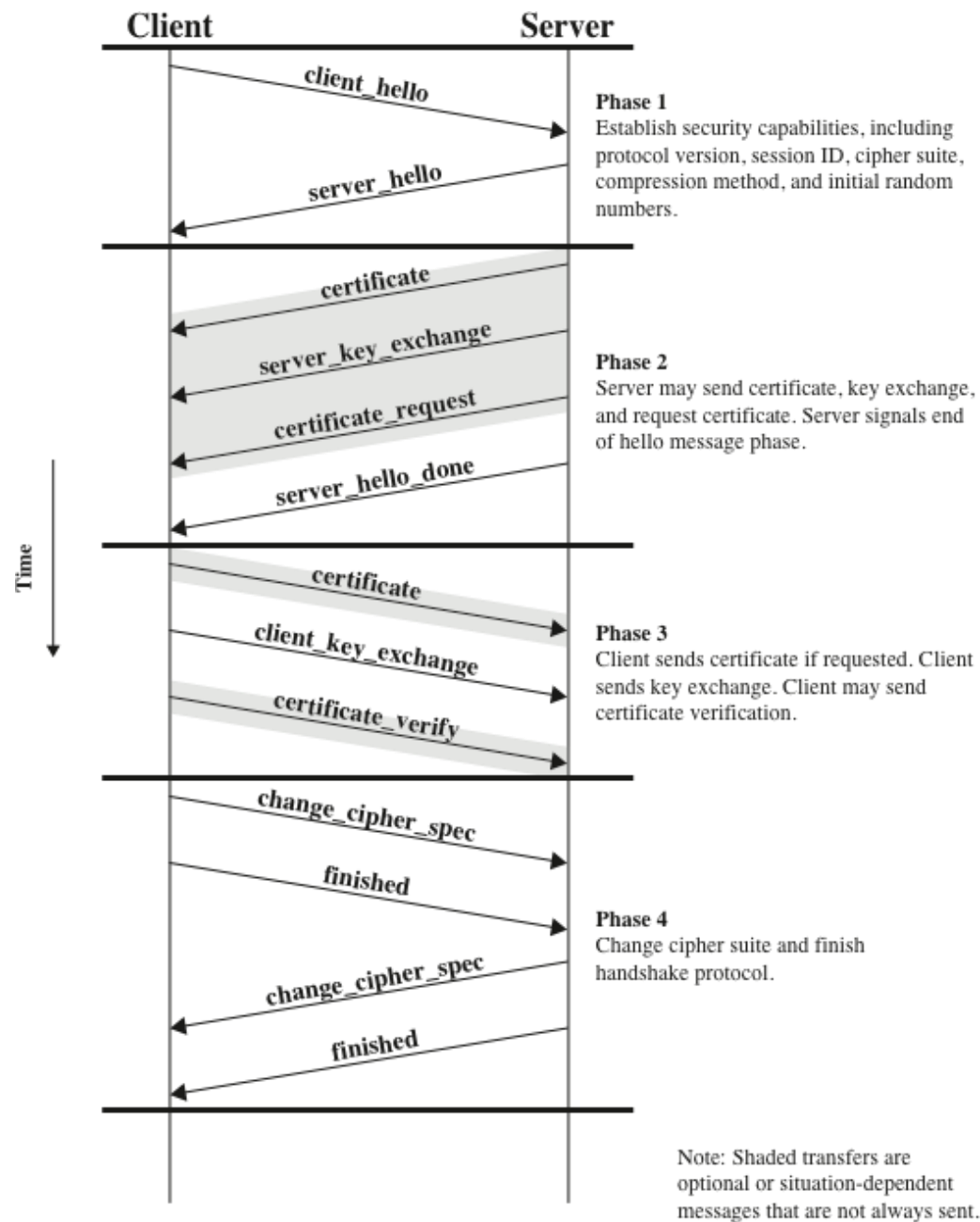


Figure 17.6 Handshake Protocol Action



Transport Layer Security (TLS)

- › An IETF standardization initiative whose goal is to produce an Internet standard version of SSL
- › Is defined as a Proposed Internet Standard in RFC 5246
 - RFC 5246 is very similar to SSLv3
 - Differences include:
 - › Version number
 - › Message Authentication Code
 - › Pseudorandom function
 - › Alert keys
 - › Cipher suites
 - › Client certificate types
 - › Certificate_verify and Finished Messages
 - › Cryptographic computations
 - › Padding

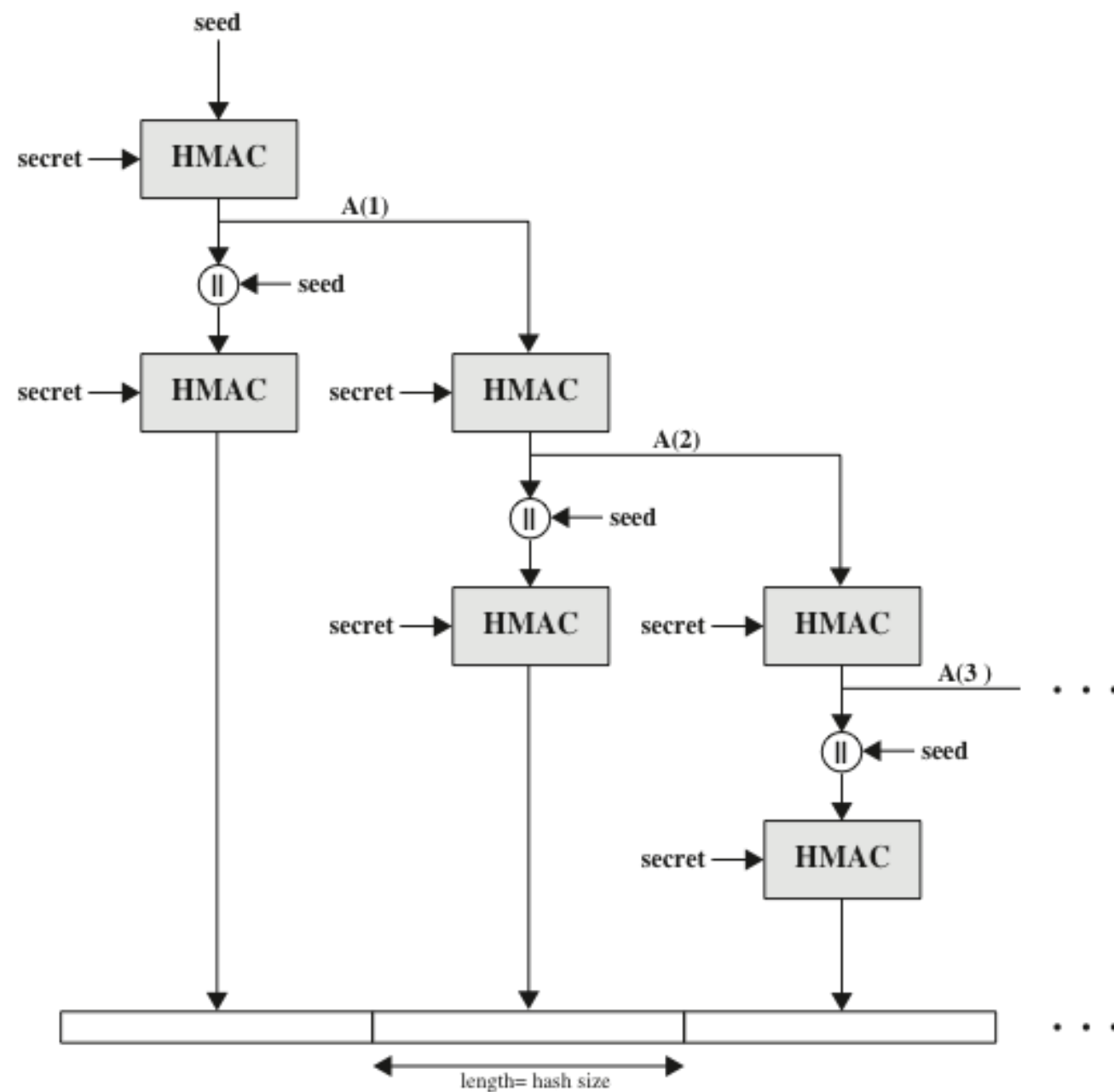


Figure 17.7 TLS Function $P_hash(secret, seed)$

HTTPS

(HTTP over SSL)

- › Refers to the combination of HTTP and SSL to implement secure communication between a Web browser and a Web server
- › The HTTPS capability is built into all modern Web browsers
- › A user of a Web browser will see URL addresses that begin with https:// rather than http://
- › If HTTPS is specified, port 443 is used, which invokes SSL
- › Documented in RFC 2818, *HTTP Over TLS*
 - There is no fundamental change in using HTTP over either SSL or TLS and both implementations are referred to as HTTPS
- › When HTTPS is used, the following elements of the communication are encrypted:
 - URL of the requested document
 - Contents of the document
 - Contents of browser forms
 - Cookies sent from browser to server and from server to browser
 - Contents of HTTP header



Connection Initiation

For HTTPS, the agent acting as the HTTP client also acts as the TLS client

The client initiates a connection to the server on the appropriate port and then sends the TLS ClientHello to begin the TLS handshake

When the TLS handshake has finished, the client may then initiate the first HTTP request

All HTTP data is to be sent as TLS application data

There are three levels of awareness of a connection in HTTPS:

At the HTTP level, an HTTP client requests a connection to an HTTP server by sending a connection request to the next lowest layer

- Typically the next lowest layer is TCP, but it may also be TLS/SSL

At the level of TLS, a session is established between a TLS client and a TLS server

- This session can support one or more connections at any time

A TLS request to establish a connection begins with the establishment of a TCP connection between the TCP entity on the client side and the TCP entity on the server side

Connection Closure

- › An HTTP client or server can indicate the closing of a connection by including the line Connection: close in an HTTP record
- › The closure of an HTTPS connection requires that TLS close the connection with the peer TLS entity on the remote side, which will involve closing the underlying TCP connection
- › TLS implementations must initiate an exchange of closure alerts before closing a connection
 - A TLS implementation may, after sending a closure alert, close the connection without waiting for the peer to send its closure alert, generating an “incomplete close”
- › An unannounced TCP closure could be evidence of some sort of attack so the HTTPS client should issue some sort of security warning when this occurs



Secure Shell (SSH)

- › Protocol for secure network communications. It is designed to be simple & inexpensive
- › SSH1 provided secure remote logon facility
 - Replace TELNET & other insecure modes
 - Also has more general client/server capability
- › SSH2 fixes a number of security flaws
- › SSH clients & servers are widely available
- › Method of choice for remote login/ X tunnels

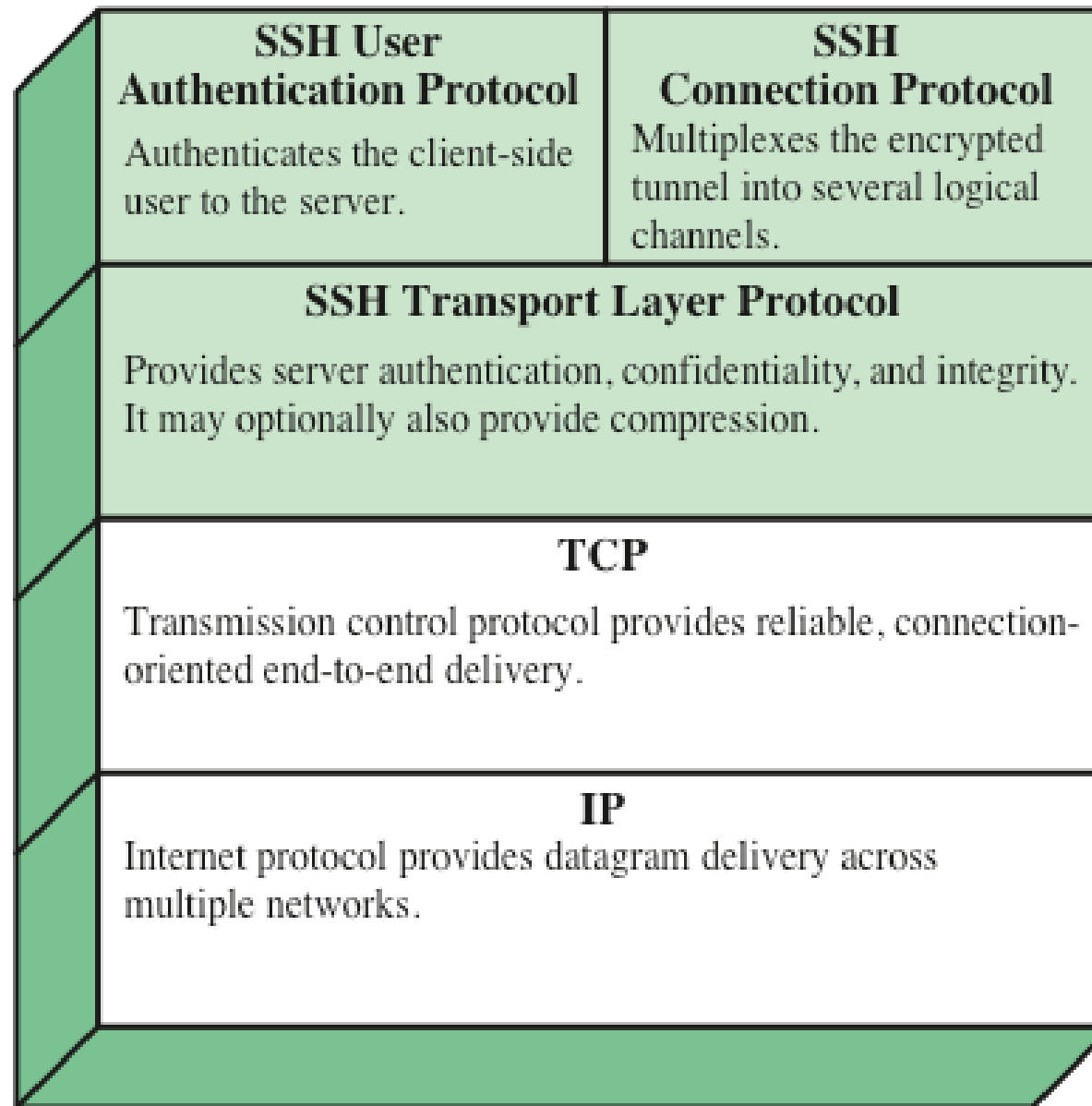


Figure 17.8 SSH Protocol Stack

SSH Transport Layer Protocol

- Server authentication occurs at the transport layer, based on the server possessing a public/private key pair
- A server may have multiple host keys using multiple different asymmetric encryption algorithms
- Multiple hosts may share the same host key
- The server host key is used during key exchange to authenticate the identity of the host
- RFC 4251 dictates two alternative trust models:
 - › The client has a local database that associates each host name with the corresponding public host key
 - › The host name-to-key association is certified by a trusted certification authority (CA); the client only knows the CA root key and can verify the validity of all host keys certified by accepted CAs

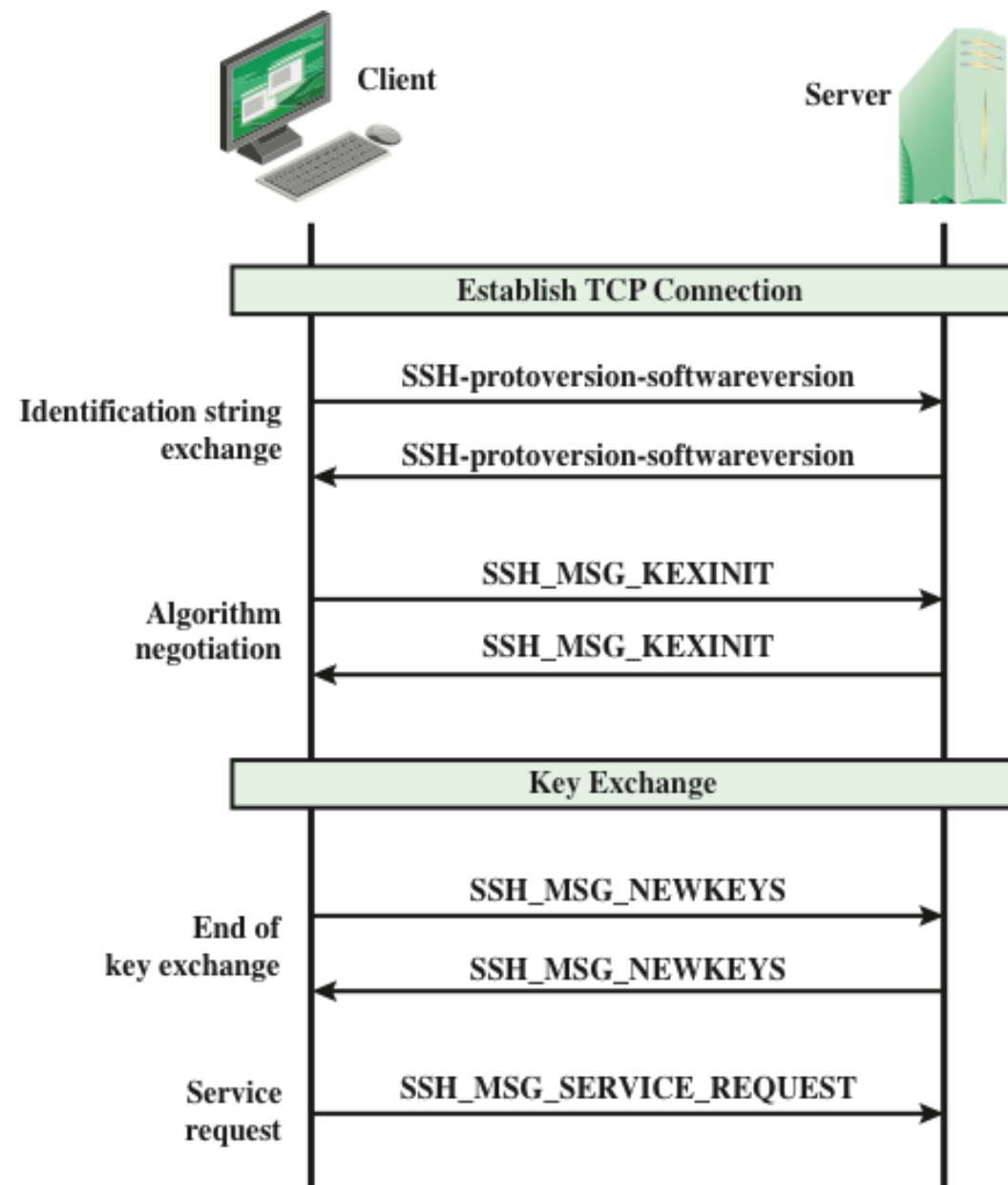


Figure 17.9 SSH Transport Layer Protocol Packet Exchanges

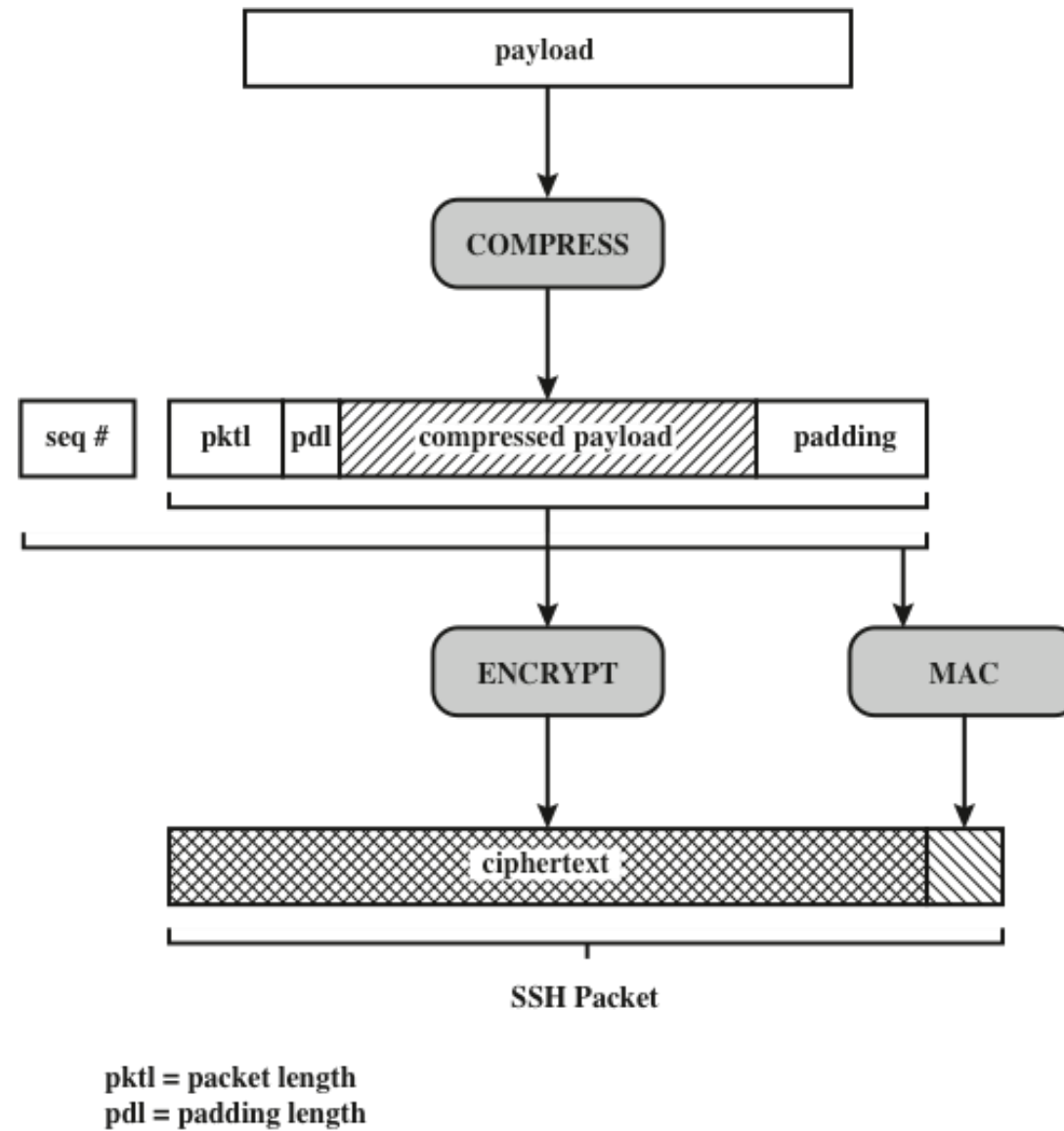


Figure 17.10 SSH Transport Layer Protocol Packet Formation

SSH User Authentication Protocol

› Publickey

- The client sends a message to the server that contains the client's public key, with the message signed by the client's private key
- When the server receives this message, it checks whether the supplied key is acceptable for authentication and, if so, it checks whether the signature is correct

› Password

- The client sends a message containing a plaintext password, which is protected by encryption by the Transport Layer Protocol

› Hostbased

- Authentication is performed on the client's host rather than the client itself
- This method works by having the client send a signature created with the private key of the client host
- Rather than directly verifying the user's identity, the SSH server verifies the identity of the client host

SSH Connection Protocol

- › The SSH Connection Protocol runs on top of the SSH Transport Layer Protocol and assumes that a secure authentication connection is in use
 - The secure authentication connection, referred to as a *tunnel*, is used by the Connection Protocol to multiplex a number of logical channels
- Channel mechanism
 - All types of communication using SSH are supported using separate channels
 - Either side may open a channel
 - For each channel, each side associates a unique channel number
 - Channels are flow controlled using a window mechanism
 - No data may be sent to a channel until a message is received to indicate that window space is available
 - The life of a channel progresses through three stages: opening a channel, data transfer, and closing a channel

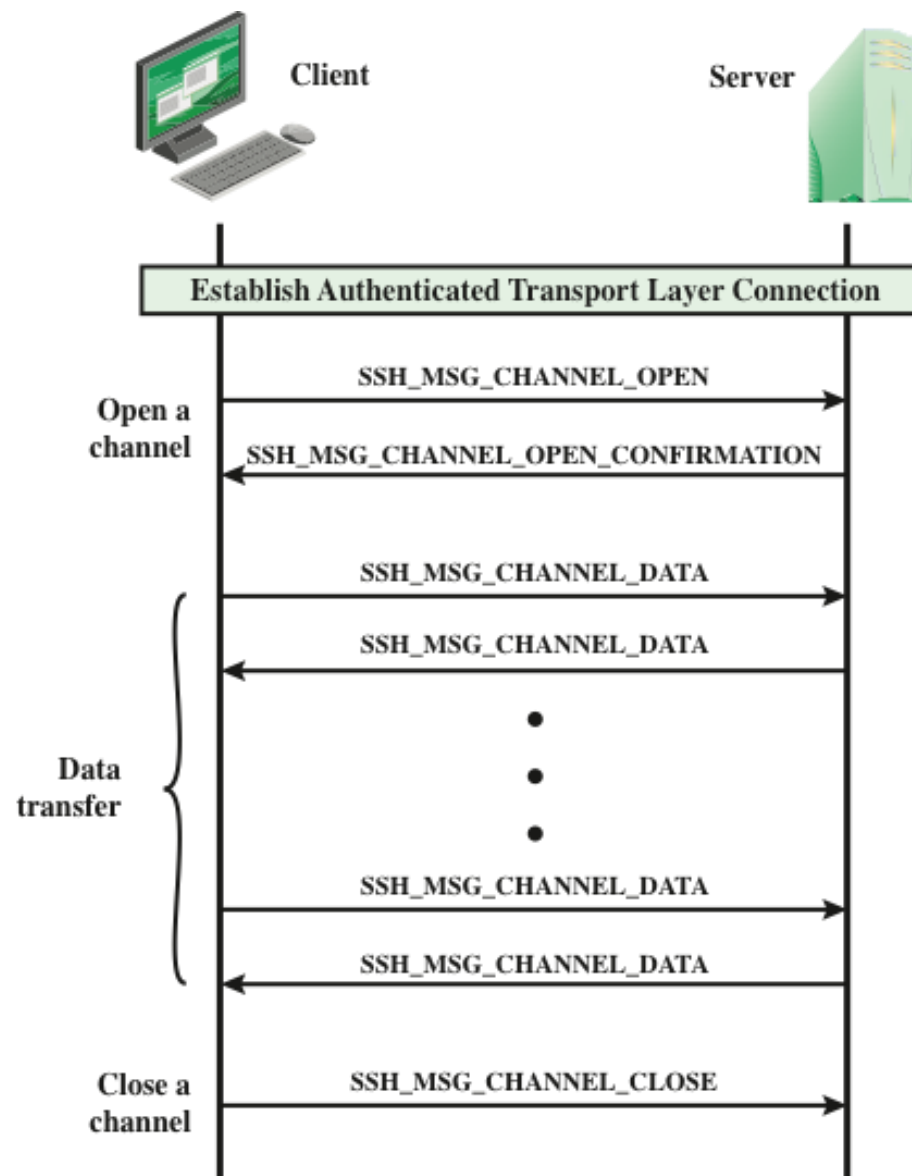


Figure 17.11 Example SSH Connection Protocol Message Exchange



Channel Types

Four channel types are recognized in the SSH Connection Protocol specification

Session

- The remote execution of a program
- The program may be a shell, an application such as file transfer or e-mail, a system command, or some built-in subsystem
- Once a session channel is opened, subsequent requests are used to start the remote program

X11

- Refers to the X Window System, a computer software system and network protocol that provides a graphical user interface (GUI) for networked computers
- X allows applications to run on a network server but to be displayed on a desktop machine

Forwarded-tcpip

- Remote port forwarding

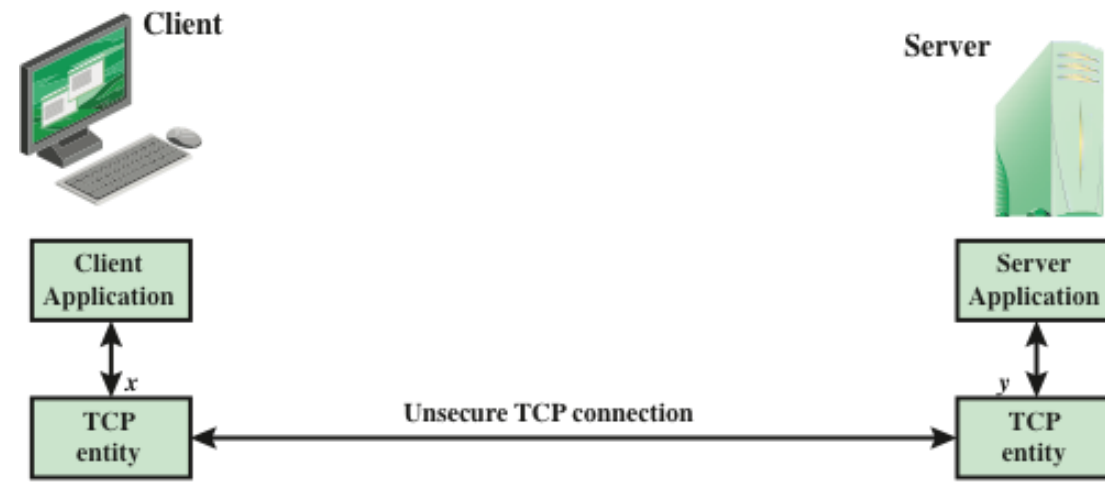
Direct-tcpip

- Local port forwarding

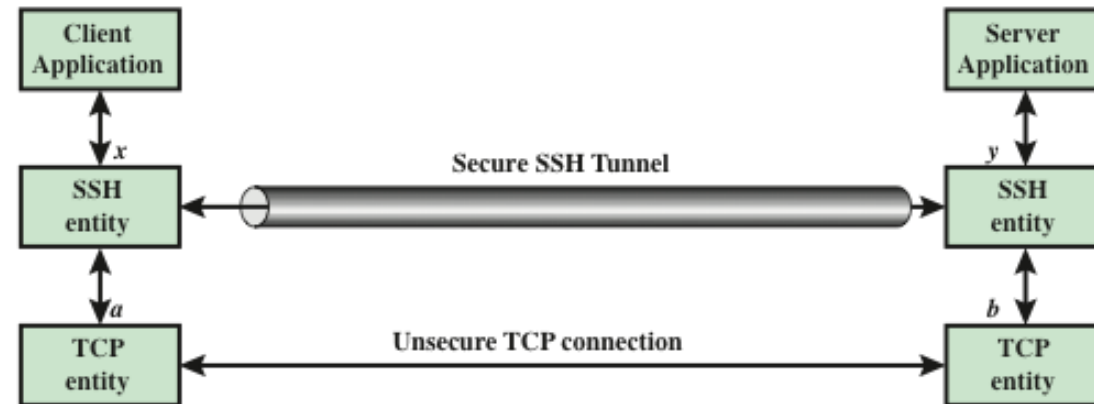


Port Forwarding

- › One of the most useful features of SSH
- › Provides the ability to convert any insecure TCP connection into a secure SSH connection (also referred to as SSH tunneling)
- › Incoming TCP traffic is delivered to the appropriate application on the basis of the port number (a port is an identifier of a user of TCP)
- › An application may employ multiple port numbers



(a) Connection via TCP



(b) Connection via SSH Tunnel

Figure 17.12 SSH Transport Layer Packet Exchanges